WEEK 5 – VAPT TOOLS

Vulnerability Assessment & Penetration Testing

Submitted By:
Amaan Fayaz

Internship Organization:
DG Interns Hub

Task:
VAPT Tools – Practical Learning

Target Used:
testphp.vulnweb.com

Tools Used:

- Nmap
- Nikto
- Burp Suite

Submission Date:
7th October 2026

Introduction to VAPT

Vulnerability Assessment and Penetration Testing (VAPT) is a security testing process used to identify weaknesses and vulnerabilities in computer systems, networks, and web applications.

Vulnerability Assessment focuses on finding and identifying potential security weaknesses, while Penetration Testing involves safely testing those weaknesses to understand their possible impact. The main purpose of VAPT is to help organizations discover security issues before they can be exploited by attackers. It also helps security teams understand the security posture of a system and take appropriate corrective measures.

Objectives of VAPT

The main objectives of this practical task are:

- To understand the basic concepts of Vulnerability Assessment and Penetration Testing.
- To learn how to perform network scanning using Nmap.
- To identify web-server issues using Nikto.
- To understand HTTP requests, headers, and cookies using Burp Suite.
- To identify and document security findings.
- To understand the importance of authorized and ethical security testing.

Authorized Target

For this practical exercise, the authorized training website provided by DG Interns Hub was used:

Target: testphp.vulnweb.com

Task 1: Nmap – Network Scanning

Introduction to Nmap: Nmap (Network Mapper) is a network scanning and security auditing tool used to discover hosts, identify open ports, and determine services running on a networked system. It is commonly used by cybersecurity professionals for network discovery and security assessment.

Nmap was used against the authorized training target: Target**:** testphp.vulnweb.com

Nmap SYN Scan

The command was used: nmap -sS testphp.vulnweb.com

The -sS option performs a TCP SYN scan. It is used to identify the state of TCP ports on the target system.



Figure 1: Nmap SYN scan of the authorized target

Observation

The target host was detected as up and responded to the scan. Nmap scanned 1,000 TCP ports, but all 1,000 ports were reported as filtered, with no open TCP ports identified by this particular scan.

The result indicates that the scanned ports did not provide responses to the SYN probes. This can occur because of network filtering, firewall rules, or other security controls. Therefore, the absence of open ports in this scan does not mean that the web application itself has no security issues.

Nmap Service Version Detection

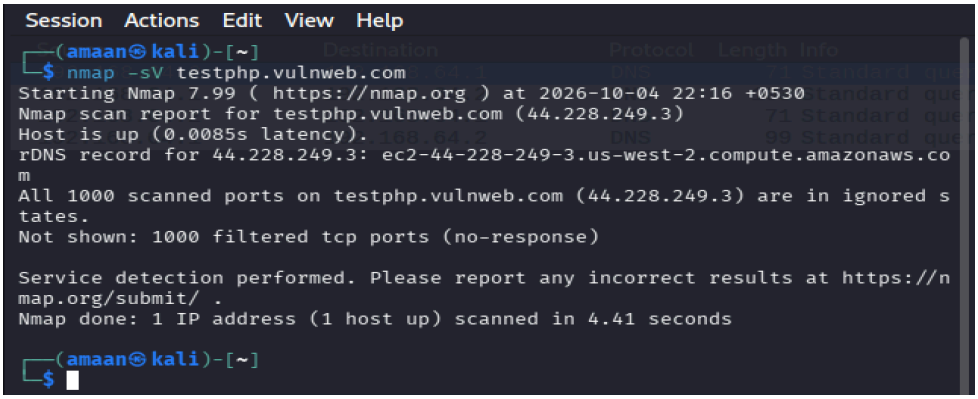


Figure 2: Nmap service version detection scan

Observation

The scan confirmed that the target host was up and reachable. Nmap scanned 1,000 TCP ports, but all of them were reported as filtered. No open TCP ports or identifiable services were detected during this scan. Service detection was performed, but there were no accessible services from which Nmap could determine versions.

Conclusion

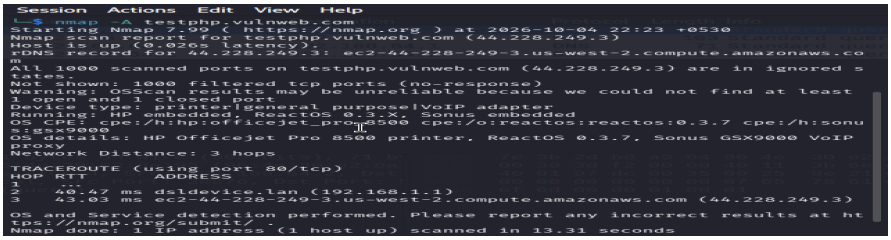
The result suggests that network filtering or firewall controls were preventing responses from the scanned TCP ports.

Nmap Aggressive Scan

Command Used: nmap -A testphp.vulnweb.com

Purpose

The -A option enables multiple advanced Nmap detection features, including service/ version detection, operating-system detection, Nmap scripting, and trace-route.



Observation:

The aggressive scan confirmed that the target host was up. Nmap scanned 1,000 TCP ports, and all 1,000 ports were reported as filtered. The scan also performed OS detection and trace-route. However, Nmap warned that the OS detection results may be unreliable because no open and closed ports were identified.

OS Detection Result

Nmap reported several possible device and operating-system matches. However, the scan explicitly warned that the OS detection results may be unreliable because it could not identify at least one open and one closed port. Therefore, these OS identification results were not treated as confirmed findings.

Trace route Result

The trace route completed successfully and indicated a network distance of approximately three hops between the scanning system and the target.

Conclusion

The aggressive scan provided additional network information, but the extensive port filtering limited the accuracy of service and OS identification. The results demonstrate the importance of interpreting automated scanning results carefully rather than treating every detected possibility as a confirmed vulnerability.

Task 2: Nikto Web Server Scanning

Introduction to Nikto

Nikto is an open-source web server scanner used to identify potentially dangerous files, outdated software, insecure configurations, and other security-related issues on web servers.

For this practical, Nikto was used against the authorized training target: Target: http://testphp.vulnweb.com

Nikto Scan Command

Command used: nikto -h http://testphp.vulnweb.com

Purpose:

The command was used to perform a web server security scan and identify possible security issues on the authorized target.

Scan Result



Figure 4: Nikto scan showing connection failure

Observation:

Nikto was unable to establish a connection with the target web server on port 80. The scan returned a connection failure.

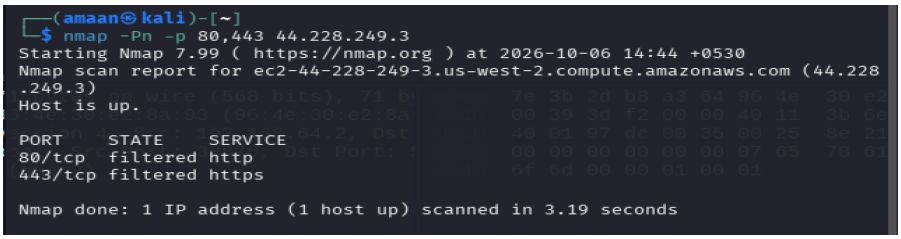


Figure 5: Nmap verification showing HTTP and HTTPS ports are filtered

Connectivity Verification

Command used:

nmap -Pn -p 80,443 44.228.249.3

Result:
The target host was detected as up, but both web ports were filtered:

- **80/tcp — filtered (HTTP)**
- **443/tcp — filtered (HTTPS)**

Conclusion:

The Nikto scan could not be completed because the target web server was unreachable from the current Kali Linux network. Connectivity testing confirmed that both HTTP (port 80) and HTTPS (port 443) were filtered. Therefore, no vulnerability findings were claimed from the Nikto scan.

Task 3: Open Burp Suite HTTP Request Analysis

Introduction to Burp Suite

Burp Suite is a web application security testing tool used to intercept, inspect, and analyze HTTP/HTTPS requests and responses between a browser and a web server. It helps security testers understand how web applications communicate and identify potential security issues.

For this practical, Burp Suite Community Edition was used against the authorized training target:

Target: http://testphp.vulnweb.com

Burp Suite Configuration

Burp Suite Proxy was configured with the local proxy listener:

Proxy: 127.0.0.1:8080

The browser was configured to send web traffic through Burp Suite so that HTTP requests could be captured and inspected.

HTTP Request Capture

A request was generated by opening the authorized target in the browser. Burp Suite successfully captured the request in Proxy → HTTP history.

Request: GET / HTTP/1.1

Host: testphp.vulnweb.com

The captured request also contained standard HTTP headers such as:

- User-Agent
- Accept
- Accept-Language
- Accept-Encoding
- Connection
- Upgrade-Insecure-Requests

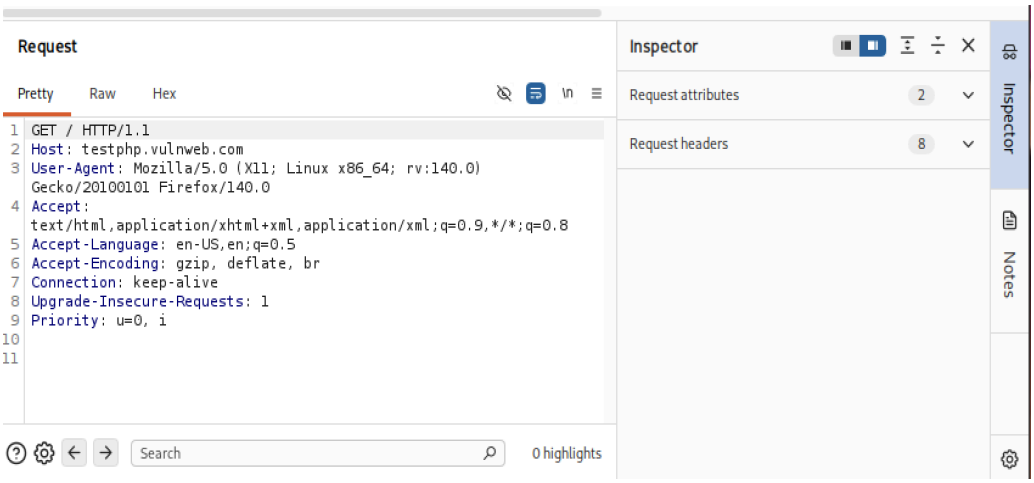


Figure 6: Burp Suite captured HTTP request and headers

Observation

Burp Suite successfully intercepted and displayed the HTTP GET request sent to the authorized target. The request headers could be inspected to understand the information transmitted by the browser.

The target did not return a successful HTTP response from the testing environment because the connection to port 80 was unavailable.

Conclusion

Burp Suite demonstrated how HTTP requests can be intercepted and analyzed during web application security testing. The practical showed the structure of an HTTP request and the role of request headers. Due to network connectivity restrictions to the target, a successful HTTP response could not be analyzed.

Findings and Security Assessment

Finding 1: TCP Ports Filtered

Tool: Nmap
Finding: Nmap reported all 1,000 scanned TCP ports as filtered.

Simple explanation: The target did not respond to the TCP port probes, which indicates that firewall or network filtering may be blocking the traffic.

Finding 2: Web Server Connection Unavailable

Tool: Nikto + Nmap
Finding: Nikto could not connect to the target on port 80. Nmap verification showed both 80/tcp and 443/tcp as filtered.

Simple explanation: The web server could not be reached from the testing environment, so Nikto could not perform its normal web vulnerability checks.

Finding 3: HTTP Request Interception

Tool: Burp Suite
Finding: Burp Suite successfully captured the GET / HTTP/1.1 request and displayed the request headers.

Simple explanation: Burp was able to intercept and inspect the information sent by the browser to the target.

Conclusion

This VAPT practical provided hands-on experience with Nmap, Nikto, and Burp Suite. Nmap was used to perform TCP port scanning, service detection, and aggressive scanning. Nikto was used to attempt web-server vulnerability scanning, while Burp Suite was used to intercept and analyze HTTP requests.

The assessment showed that the target was reachable at the host level, but its TCP ports were filtered from the testing environment. As a result, Nikto could not complete its web-server scan, and Burp Suite could not analyze a successful HTTP response. The practical demonstrated the importance of network connectivity, firewall controls, and careful interpretation of automated security-testing results.